

User ID Controlled by Request Parameter

Lab Information

Field	Value
Category	Access Control
Difficulty	Apprentice
Vulnerability	Insecure Direct Object Reference (IDOR)

Summary

This lab demonstrates an **IDOR (Insecure Direct Object Reference)** vulnerability that leads to **Horizontal Privilege Escalation**. The application uses a user-controlled parameter to identify accounts but fails to verify whether the authenticated user is authorized to access the requested account.

By modifying the user identifier in the request, an attacker can access another user's account information and retrieve sensitive data such as the API key.

Objective

Obtain the API key belonging to the user **carlos**.

Attack Scenario

The application provides a user account page where account information is retrieved based on a user-controlled identifier.

The server trusts the supplied `userId` parameter without verifying ownership of the requested account. As a result, an authenticated user can replace their own identifier with another user's identifier and access their private information.

Steps to Reproduce

1. Log in using the provided credentials:

Username: wiener
Password: peter

1. Navigate to the account page.
2. Observe the request containing the user identifier.

Example:

userId=wiener

1. Modify the parameter value:

Before:

userId=wiener

After:

userId=carlos

1. Send the modified request.
2. Observe that the account page for **carlos** is returned.
3. Extract the API key from the response.
4. Submit the API key to solve the lab.

Evidence

Original Request

The application used a user-controlled identifier:

userId=wiener

Modified Request

The identifier was changed to another user's value:

```
userId=carlos
```

Result

The application returned Carlos's account information, including his API key.

Security Impact

An attacker can access sensitive information belonging to other users without authorization. Depending on the affected functionality, this vulnerability can expose personal data, account information, API keys, orders, messages, or allow unauthorized account actions.

Root Cause

The application relied on the user-supplied identifier to locate account data but failed to implement proper authorization checks to verify whether the authenticated user had permission to access the requested resource.

Remediation

- Always perform server-side authorization checks before returning user-specific data.
 - Do not rely only on authentication; verify resource ownership.
 - Avoid exposing predictable direct references to sensitive objects.
 - Use indirect references or server-side mapping where appropriate.
-

Pentester's Notes

When testing authenticated functionality, parameters that reference objects should be considered potential IDOR candidates. Common examples include:

- `userId`
- `accountId`
- `profileId`
- `orderId`
- `documentId`

A useful testing approach is to modify these identifiers and observe whether another user's data becomes accessible.

Key Takeaways

- Authentication only confirms who the user is; authorization determines what they can access.
- Any user-controlled object reference should be tested for access control issues.
- IDOR vulnerabilities commonly lead to horizontal privilege escalation.
- Changing a single parameter can expose another user's sensitive information.